

تقرير التقييم الأمني لتطبيق OWASP Juice Shop

1. الملخص التنفيذي

Executive Summary

تم إجراء هذا التقييم الأمني على تطبيق **OWASP Juice Shop** داخل بيئة تدريبية مصرح بها. يهدف الاختبار إلى تطبيق عدد من تقنيات وأدوات الاختبار الأمني وتحليل التطبيق والشبكة، مع الالتزام بالنطاق المحدد وعدم استهداف أي أنظمة غير مصرح بها.

تم استخدام أدوات **Nmap** و **Nikto** و **Burp Suite** و **Wireshark** لفحص الخدمات الشبكية، وإعدادات خادم الويب، وطلبات واستجابات التطبيق، وحركة مرور الشبكة.

خلال عملية التقييم تم تسجيل ثلاث نتائج أمنية رئيسية، وهي: غياب بعض ترويسات الحماية الأمنية، واستخدام اتصال HTTP غير مشفر، وإمكانية الوصول إلى معلومات خاصة بإعدادات التطبيق.

تم توثيق نتائج الاختبارات باستخدام لقطات شاشة، كما تم تقديم عدد من التوصيات التي يمكن أن تساعد في تحسين مستوى أمان التطبيق.

2. النطاق وقواعد الاختبار

Scope & Rules of Engagement

تم تنفيذ الاختبار الأمني على تطبيق **OWASP Juice Shop** الموجود داخل بيئة افتراضية مخصصة للتدريب.

كان التطبيق يعمل على جهاز الضحية من خلال عنوان:

192.168.56.101

وكان التطبيق متاحًا من خلال المنفذ:

3000

تم تنفيذ الاختبارات من جهاز المهاجم باستخدام نظام **Kali Linux**.

تم الالتزام أثناء التقييم بعدم تجاوز نطاق الاختبار المحدد، وعدم إجراء أي اختبارات على أجهزة أو مواقع أخرى غير مصرح بها. كما تم تجنب تنفيذ أي نشاط قد يؤدي إلى تعطيل الخدمة أو حذف أو إتلاف البيانات.

تم استخدام الأدوات فقط لأغراض التدريب والتقييم الأمني داخل المختبر المخصص للمشروع، وهو ما يتفق مع تعليمات المشروع المتعلقة بتحديد النطاق والتصريح قبل إجراء الاختبارات. واجب

3. المنهجية

Methodology

تم تنفيذ التقييم الأمني على عدة مراحل باستخدام الأدوات المطلوبة في المشروع. بدأت العملية بالتأكد من إمكانية الاتصال بين جهاز المهاجم وجهاز الضحية، ثم تم إجراء فحص للشبكة والخدمات المتاحة.

تم استخدام أداة **Nmap** لفحص جهاز الضحية وتحديد المنافذ المفتوحة والخدمات المتاحة. أظهر الفحص أن المنفذ 3000/TCP مفتوح ويستخدم لتشغيل تطبيق OWASP Juice Shop.

بعد ذلك تم استخدام أداة **Nikto** لفحص خادم الويب والبحث عن بعض الإعدادات الأمنية غير المكتملة أو الملاحظات المتعلقة بأمان الخادم.

ثم تم استخدام **Burp Suite** لمراقبة وتحليل طلبات واستجابات HTTP بين المتصفح وتطبيق Juice Shop. تم من خلاله ملاحظة عدد من المسارات التي يستخدمها التطبيق وتحليل بعض الاستجابات التي يعيدها الخادم.

وفي المرحلة التالية تم استخدام **Wireshark** لتحليل حركة مرور الشبكة بين جهاز المهاجم وجهاز الضحية ومراقبة حزم HTTP المرسل عبر الشبكة.

تم توثيق نتائج كل مرحلة باستخدام لقطات شاشة لاستخدامها كأدلة داخل التقرير. ويتوافق هذا التسلسل مع مراحل التقييم والأدوات المحددة في المشروع. واجب

4. الأدوات المستخدمة

Tools Used

الأداة	الاستخدام
Nmap	فحص المنافذ والخدمات الموجودة على جهاز الضحية
Nikto	فحص خادم الويب والملاحظات الأمنية
Burp Suite	مراقبة وتحليل طلبات واستجابات HTTP
Wireshark	تحليل حركة مرور الشبكة والحزم

5. النتائج الأمنية

Security Findings

النتيجة الأولى: غياب بعض ترويسات الحماية الأمنية

Missing Security Headers

مستوى الخطورة: متوسط - Medium

الوصف

أثناء فحص خادم الويب باستخدام أداة **Nikto**، ظهرت عدة ملاحظات تشير إلى غياب بعض ترويسات الحماية الأمنية الموصى بها.

من أمثلة الترويسات التي ظهرت في نتيجة الفحص:

Content-Security-Policy

Permissions-Policy

Strict-Transport-Security

Referrer-Policy

الدليل

أظهرت نتيجة Nikto رسائل تشير إلى أن هذه الترويسات الأمنية غير موجودة في استجابة الخادم.

[ضعي هنا صورة Nikto التي تظهر [Missing Security Headers]

شكل ١: نتائج فحص خادم الويب باستخدام Nikto

التأثير

غياب بعض ترويسات الحماية قد يقلل من مستوى الحماية الذي يوفره المتصفح، وقد يجعل التطبيق أكثر عرضة لبعض المخاطر المتعلقة بتطبيقات الويب حسب طبيعة التطبيق وطريقة استخدامه.

التوصية

يوصى بإضافة وضبط ترويسات الحماية المناسبة في خادم الويب، ومن أمثلتها-Content-Security-Policy وReferrer-Policy، مع ضبط بقية الترويسات بناءً على احتياجات التطبيق.

النتيجة الثانية: استخدام اتصال HTTP غير مشفر

Unencrypted HTTP Communication

مستوى الخطورة: متوسطMedium -

الوصف

تمت ملاحظة أن تطبيق OWASP Juice Shop يعمل باستخدام بروتوكول HTTP على المنفذ 3000 دون استخدام تشفير HTTPS.

تم التأكد من ذلك باستخدام أداة Wireshark ، حيث أمكن رؤية طلبات HTTP المرسلة بين جهاز المهاجم وجهاز الضحية.

الدليل

أظهر Wireshark طلبًا مثل:

GET /assets/public/images/products/grape_juice.png HTTP/1.1

كما ظهر رد الخادم:

HTTP/1.1 304 Not Modified

وكان الاتصال يتم بين:

192.168.56.102

وجهاز الضحية:

192.168.56.101

على المنفذ:

3000

[ضعي هنا صورة Wireshark التي تظهر HTTP وGET]

شكل ٢: تحليل حركة HTTP باستخدام Wireshark

التأثير

استخدام HTTP دون تشفير يعني أن البيانات تنتقل عبر الشبكة دون حماية TLS. وفي شبكة غير موثوقة قد يتمكن شخص لديه إمكانية مراقبة مسار الاتصال من الاطلاع على بعض البيانات المتبادلة.

التوصية

يوصى باستخدام HTTPS مع إعداد TLS مناسب لتشفير الاتصال بين المستخدم والخادم وحماية البيانات أثناء انتقالها عبر الشبكة.

النتيجة الثالثة: كشف معلومات إعدادات التطبيق

Application Configuration Information Disclosure

مستوى الخطورة: منخفض Low -

الوصف

أثناء استخدام Burp Suite تم ملاحظة إمكانية الوصول إلى المسار التالي:

/rest/admin/application-configuration

وقد أعاد الخادم استجابة ناجحة:

HTTP/1.1 200 OK

وكان نوع البيانات:

application/json

وتضمنت الاستجابة معلومات تتعلق بإعدادات التطبيق، مثل اسم التطبيق وبعض تفاصيل الإعداد والتشغيل.

الدليل

تم استخدام Burp Suite لمشاهدة الطلب والاستجابة الخاصة بالمسار، وكانت الاستجابة تحتوي على معلومات عن إعدادات التطبيق.

[ضعي هنا صورة Burp Suite التي تظهر Response الخاص بـ application-configuration]

شكل ٣: استجابة Application Configuration في Burp Suite

التأثير

كشف تفاصيل إضافية عن إعدادات التطبيق قد يساعد في جمع معلومات عن بنية التطبيق وبيئته، ويمكن استخدام هذه المعلومات في مراحل استطلاع أخرى.

التوصية

يوصى بمراجعة المعلومات التي يعيدها هذا المسار وتقليل البيانات غير الضرورية التي يتم إرسالها إلى المستخدم، والتأكد من عدم كشف أي معلومات حساسة دون الحاجة إليها أو دون صلاحيات مناسبة.

6. نتائج الفحص الشبكي

Network Scanning Result

تم استخدام أداة Nmap لفحص جهاز الضحية على المنفذ 3000.

تم تنفيذ الفحص على عنوان:

192.168.56.101

وأظهرت النتيجة أن الجهاز يعمل وأن المنفذ 3000/TCP مفتوح.

مثال من نتيجة الفحص:

PORT STATE SERVICE

3000/tcp open

ساعد هذا الفحص في التأكد من أن تطبيق الويب يعمل على المنفذ المحدد ويمكن الوصول إليه من جهاز المهاجم.

[ضعي هنا صورة Nmap التي يظهر فيها Port 3000 Open]

شكل ٤: نتيجة Network Scanning باستخدام Nmap

7. ملخص المخاطر

Risk Summary

يوضح الجدول التالي ملخص النتائج الأمنية التي تم تسجيلها أثناء عملية التقييم:

مستوى الخطورة النتيجة الأمنية

متوسط غياب بعض ترويسات الحماية الأمنية

متوسط استخدام اتصال HTTP غير مشفر

مستوى الخطورة النتيجة الأمنية

منخفض كشف معلومات إعدادات التطبيق

لم يتم ضمن الاختبارات التي تم تنفيذها في هذا المشروع تسجيل نتيجة مصنفة على أنها عالية الخطورة. ومع ذلك، فإن معالجة النتائج السابقة تساعد على تحسين مستوى الأمان وتقليل كمية المعلومات التي يمكن كشفها عن التطبيق.

8. التوصيات العامة

Recommendations

بناءً على نتائج التقييم الأمني، يوصى بتنفيذ HTTPS واستخدام TLS لحماية البيانات أثناء انتقالها عبر الشبكة، وإضافة وضبط ترويسات الحماية الأمنية المناسبة ل خادم الويب.

كما يوصى بمراجعة المسارات التي تعيد معلومات عن إعدادات التطبيق والتأكد من عدم إرسال معلومات غير ضرورية إلى المستخدمين. ويجب كذلك مراجعة إعدادات التطبيق والخادم بشكل دوري وإجراء اختبارات أمنية منتظمة للتأكد من عدم وجود إعدادات غير آمنة أو معلومات مكشوفة.

9. الخلاصة

Conclusion

تم في هذا المشروع إجراء تقييم أمني لتطبيق OWASP Juice Shop داخل بيئة تدريبية مصرح بها باستخدام مجموعة من أدوات اختبار وتحليل الأمن السيبراني.

تم استخدام Nmap للتعرف على المنافذ والخدمات، و Nikto لفحص إعدادات خادم الويب، و Burp Suite لتحليل طلبات واستجابات التطبيق، و Wireshark لتحليل حركة مرور الشبكة.

أسفر التقييم عن ثلاث نتائج أمنية رئيسية بمستويات خطورة متفاوتة بين منخفض ومتوسط. وتم تقديم توصيات لمعالجة هذه الملاحظات وتحسين مستوى حماية التطبيق.

ساهم المشروع في تطبيق مراحل التقييم الأمني بشكل عملي، بداية من الاستطلاع والفحص وانتهاءً بتحليل النتائج وتوثيق الأدلة وكتابة التقرير الأمني النهائي.

الأدلة

Evidence

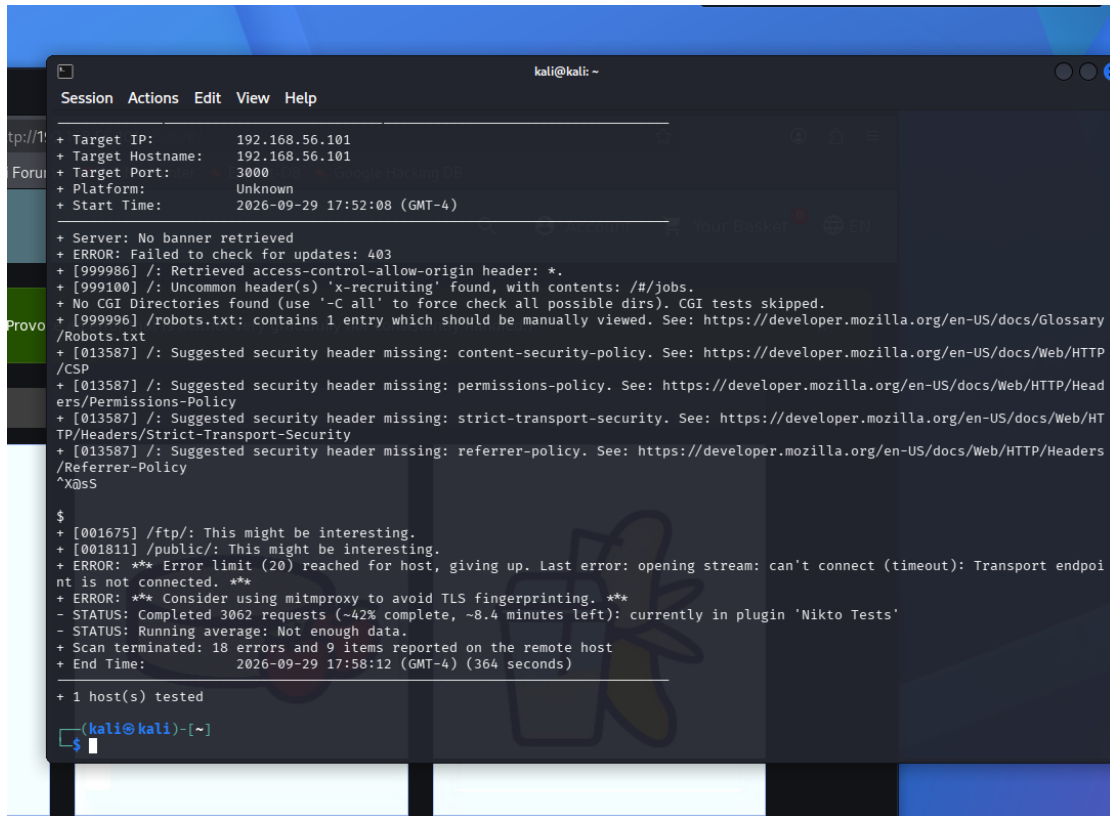
ضعي في آخر التقرير الصور بهذا الترتيب:

الشكل 1: نتيجة Nikto التي تظهر الثروبيسات الأمنية المفقودة.

الشكل 2: نتيجة Wireshark التي تظهر حركة HTTP.

الشكل 3: نتيجة Burp Suite لمسار `/rest/admin/application-configuration`.

الشكل 4: نتيجة Nmap التي تظهر أن المنفذ 3000 مفتوح.



```
kali@kali: ~  
Session Actions Edit View Help  
+ Target IP: 192.168.56.101  
+ Target Hostname: 192.168.56.101  
+ Target Port: 3000  
+ Platform: Unknown  
+ Start Time: 2026-09-29 17:52:08 (GMT-4)  
  
+ Server: No banner retrieved  
+ ERROR: Failed to check for updates: 403  
+ [999986] /: Retrieved access-control-allow-origin header: *.  
+ [999100] /: Uncommon header(s) 'x-recruiting' found, with contents: /#/jobs.  
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.  
+ [999996] /robots.txt: contains 1 entry which should be manually viewed. See: https://developer.mozilla.org/en-US/docs/Glossary/Robots.txt  
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP  
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy  
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security  
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy  
*x@sS  
$  
+ [001675] /ftp/: This might be interesting.  
+ [001811] /public/: This might be interesting.  
+ ERROR: *** Error limit (20) reached for host, giving up. Last error: opening stream: can't connect (timeout): Transport endpoint is not connected. ***  
+ ERROR: *** Consider using mitmproxy to avoid TLS fingerprinting. ***  
- STATUS: Completed 3062 requests (~42% complete, ~8.4 minutes left): currently in plugin 'Nikto Tests'  
- STATUS: Running average: Not enough data.  
+ Scan terminated: 18 errors and 9 items reported on the remote host  
+ End Time: 2026-09-29 17:58:12 (GMT-4) (364 seconds)  
  
+ 1 host(s) tested  
~(kali@kali)-[~]  
$
```

[illegible]

```
kali@kali: ~  
Session Actions Edit View Help  
64 bytes from 192.168.56.101: icmp_seq=12 ttl=64 time=2.04 ms  
64 bytes from 192.168.56.101: icmp_seq=13 ttl=64 time=3.21 ms  
64 bytes from 192.168.56.101: icmp_seq=14 ttl=64 time=1.01 ms  
64 bytes from 192.168.56.101: icmp_seq=15 ttl=64 time=6.78 ms  
64 bytes from 192.168.56.101: icmp_seq=16 ttl=64 time=1.22 ms  
64 bytes from 192.168.56.101: icmp_seq=17 ttl=64 time=2.81 ms  
64 bytes from 192.168.56.101: icmp_seq=18 ttl=64 time=3.21 ms  
64 bytes from 192.168.56.101: icmp_seq=19 ttl=64 time=3.15 ms  
^C  
— 192.168.56.101 ping statistics —  
19 packets transmitted, 19 received, 0% packet loss, time 18375ms  
rtt min/avg/max/mdev = 0.906/2.330/6.779/1.343 ms  
  
(kali@kali)-[~]  
$ nmap -sV -p 3000 192.168.56.101  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-29 17:46 -0400  
Stats: 0:00:06 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan  
Service scan Timing: About 0.00% done  
Nmap scan report for 192.168.56.101  
Host is up (0.0015s latency).  
  
PORT      STATE SERVICE VERSION  
3000/tcp  open  ppp?  
1 service unrecognized despite returning data. If you know the service/version, please submit the following finger  
: //nmap.org/cgi-bin/submit.cgi?new-service :  
SF-Port3000-TCP:V=7.99%I=7%D=9/29%Time=6ABC31AC%P=x86_64-pc-linux-gnu%r(Ge  
SF:tRequest,2668,"HTTP/1.1\x20200K\r\nAccess-Control-Allow-Origin:\x  
SF:20*\r\nX-Content-Type-Options:\x20nosniff\r\nX-Frame-Options:\x20SAMEO  
SF:RIGIN\r\nFeature-Policy:\x20payment\x20'self'\r\nX-Recruiting:\x20/#/ip
```